

HỆ THỐNG VELSTRONG BOOKSTORE (SPACE BOOK)

TÀI LIỆU TOÀN DIỆN VỀ CÁC VAI TRÒ (ROLES) VÀ TÍNH NĂNG NGHIỆP VỤ

MỤC LỤC

- 1. [Tổng Quan Hệ Thống & Kiến Trúc Phần Mềm](#)
- 2. [Mô Hình Phân Quyền Theo Vai Trò \(RBAC Architecture\)](#) - 2.1. Kiến Trúc Bảo Mật: JWT, Redis Denylist & Session Versioning - 2.2. Chi Tiết 4 Vai Trò (Role Types) - 2.3. Ma Trận Phân Quyền (23 Permissions & Endpoint Authorization)
- 3. [Phân Tích Chi Tiết 11 Phân Hệ Tính Năng Nghiệp Vụ](#) - 3.1. Phân Hệ Xác Thực & Tài Khoản (Auth & Identity) - 3.2. Phân Hệ Danh Mục Sách & Quản Lý Bản Sao Kho (Books & Inventory) - 3.3. Phân Hệ Giỏ Hàng Đa Hình (Dual-mode Shopping Cart) - 3.4. Phân Hệ Khuyến Mãi & Voucher Engine (Quote, Reserve, Commit) - 3.5. Phân Hệ Đặt Hàng & Quản Lý Vòng Đời Đơn Hàng (Order Lifecycle) - 3.6. Phân Hệ Thanh Toán & Đối Soát Ngân Hàng Tự Động (Payment & Bank Reconciliation) - 3.7. Phân Hệ Thuê Sách & Gói Hội Viên Đọc Sách (Rentals & Subscriptions) - 3.8. Phân Hệ Hỗ Trợ Khách Hàng Trực Tuyến (Live Support Chat) - 3.9. Phân Hệ Đánh Giá Sách Đã Xác Minh (Verified Reviews) - 3.10. Phân Hệ Thông Báo Đa Kênh & Thời Gian Thực (SSE & Web Push) - 3.11. Phân Hệ Quản Trị Nội Dung & Blog Sách (Editorial CMS)
- 4. [Bảng Tổng Hợp REST API Endpoints Toàn Hệ Thống](#)

1. TỔNG QUAN HỆ THỐNG & KIẾN TRÚC PHẦN MỀM

Dự án **Velstrong Bookstore (Space Book)** là nền tảng thương mại điện tử chuyên biệt kết hợp hai mô hình: **Mua bán sách truyền thống** và **Dịch vụ cho thuê sách vật lý linh hoạt / Gói đọc sách hội viên**. Hệ thống được xây dựng phục vụ chương trình Thạc sĩ ngành Kỹ thuật Phần mềm / Cơ sở dữ liệu nâng cao (Đại học Công nghiệp Hà Nội - HaUI).

1.1. Kiến trúc tổng thể (Hexagonal Architecture & DDD)

Hệ thống áp dụng nghiêm ngặt mô hình **Kiến trúc Lục giác (Ports & Adapters)** phối hợp cùng **Domain-Driven Design (DDD)**: - **Lõi nghiệp vụ (Domain Core - `com.velstrong.bookstore.domain`)**: - Độc lập 100% với Spring Framework, JPA, Jackson hoặc MongoDB driver. - Chứa Domain Entities, Aggregates, Value Objects, Domain Exceptions và các cổng giao tiếp (Inbound Ports / Use Cases, Outbound Ports / SPIs). - Quy tắc bất biến: Tiền tệ luôn dùng kiểu số nguyên `Long` (VND), không dùng số thực `float / double`. Thời gian luôn được inject thông qua `java.time.Clock`. - **Tầng ứng dụng (Application Layer - `com.velstrong.bookstore.application`)**: - Triển khai các Use Case Interfaces (`@Service`), đóng gói Use Case Commands và DTO Responses. - Điều phối các Domain Model và Driven Ports; chịu trách nhiệm phân chia ranh giới giao dịch (`@Transactional`). - **Tầng hạ tầng (Infrastructure Layer - `com.velstrong.bookstore.infrastructure`)**: - Inbound Adapters: REST Controllers (`@RestController`), xử lý HTTP requests, validation DTOs. - Outbound Persistence Adapters: Bộ adapter MongoDB 7 (mặc định) sử dụng `MongoTemplate` và bộ adapter PostgreSQL 17 (chế độ fallback/migration). - Outbound External Adapters: Email SMTP (Gmail), VNPAY Payment Gateway, VietQR Generator (BVBank / Timo), Redis Token Denylist, Web Push (VAPID Service Worker), Server-Sent Events (SSE).

1.2. Tech Stack

- **Backend**: Java 21 LTS, Spring Boot 4 / Spring Framework 7, Spring Security 7, Spring Data MongoDB, Redis 7 (Lettuce), Caffeine Cache.
- **Frontend**: Next.js 15 (React 19 App Router), TypeScript, Tailwind CSS, Turbopack, Lucide Icons.

- **Cơ sở dữ liệu:** MongoDB 7 Replica Set `rs0` (hỗ trợ Multi-document ACID Transactions), Redis 7 (Caching & Denylist).

2. MÔ HÌNH PHÂN QUYỀN THEO VAI TRÒ (RBAC ARCHITECTURE)

Hệ thống triển khai mô hình **Phân quyền dựa trên quyền hạn và vai trò (Role-Based Access Control - RBAC)** có khả năng mở rộng linh hoạt: Người dùng (`users`) $\rightarrow$ Vai trò (`roles`) $\rightarrow$ Quyền hạn (`permissions`).

2.1. Kiến trúc bảo mật: JWT, Redis Denylist & Session Versioning

1. **Stateless JWT:** - Access Token: Hiệu lực ngắn (1 giờ - 3600 giây), chứa thông tin `sub` (userId), `username`, danh sách `roles` và `permissions`. - Refresh Token: Hiệu lực dài (7 ngày - 604800 giây), dùng để cấp phát Access Token mới mà không yêu cầu người dùng đăng nhập lại.
2. **Cơ chế thu hồi phiên tức thì (Instant Session Invalidation):** - Trong kiến trúc JWT thuần túy, token đã phát hành không thể hủy trước khi hết hạn. Velstrong Bookstore giải quyết bằng cơ chế kết hợp hai lớp:
 - **Lớp 1 - Redis Token Denylist:** Khi gọi `/api/v1/auth/logout`, chữ ký của Access Token hiện tại được lưu vào Redis với TTL bằng thời gian sống còn lại của token. Bất kỳ request nào mang token trong denylist đều bị từ chối ngay lập tức.
 - **Lớp 2 - Session Versioning:** Mỗi người dùng có một số phiên bản phiên làm việc (`version`) lưu tại collection `user_session_versions`. Khi người dùng đổi mật khẩu hoặc đăng xuất từ mọi thiết bị, hệ thống gọi `incrementVersion(userId)`. Token cũ mang `sessionVersion` thấp hơn phiên bản hiện tại sẽ bị `SecurityConfig` từ chối tự động.

2.2. Chi tiết 4 Vai Trò Hệ Thống (Role Types)

Mã Vai Trò (<code>code</code>)	Tên Hiện Thị	Đối Tượng Người Dùng	Trách Nhiệm & Giới Hạn Nghiệp Vụ
CUSTOMER	Khách hàng	Người dùng cá nhân, độc giả mua/thuê sách	Xem danh mục sách, quản lý giỏ hàng, đặt hàng (mua/thuê), áp dụng voucher, thanh toán VNPay/Chuyển khoản VietQR, quản lý đơn hàng cá nhân, trả sách thuê, mua gói hội viên, đánh giá sách đã mua, chat hỗ trợ, nhận thông báo.
SALES_STAFF	Nhân viên Bán hàng & Thu ngân	Nhân viên vận hành tại quầy hoặc nhân viên chăm sóc khách hàng	Xem toàn bộ đơn hàng hệ thống, cập nhật trạng thái đơn hàng (xác nhận, giao hàng), quản lý quy trình nhận trả sách thuê (<code>rental:checkin</code>), tạo đơn tại quầy, xử lý hoàn tiền, đối soát thanh toán ngân hàng chuyển khoản không khớp, trực chat hỗ trợ khách hàng.
WAREHOUSE_MANAGER	Thủ kho / Quản lý Kho	Quản lý kho sách vật lý, nhân viên logistics	Quản lý từng bản sao vật lý của sách (<code>BookCopy</code>), gán mã định danh, tình trạng sách (<code>NEW</code> , <code>GOOD</code> , <code>FAIR</code> , <code>POOR</code>), trạng thái bản sao (<code>AVAILABLE</code> , <code>RENTED</code> , <code>DAMAGED</code> , <code>LOST</code>), nhập kho, kiểm kê hàng tồn kho, điều chỉnh số lượng tồn.
ADMIN	Quản trị viên hệ thống	Ban quản trị, Giám đốc điều hành, Technical Lead	Toàn quyền kiểm soát hệ thống: Quản trị danh mục sách, quản trị khuyến mãi & voucher, quản lý gói cước hội viên, quản lý tài khoản người dùng, phân quyền vai

Mã Vai Trò (code)	Tên Hiển Thị	Đối Tượng Người Dùng	Trách Nhiệm & Giới Hạn Nghiệp Vụ
			trò, xem báo cáo doanh thu & xuất nhập tồn, cấu hình hệ thống.

2.3. Ma Trận Phân Quyền (23 Permissions & Endpoint Authorization)

Hệ thống định nghĩa 23 quyền hạn nguyên tử (KnownPermissions.java) và tự động nạp chính sách bảo mật endpoint từ security-endpoints.yml :

Mã Quyền Hạn (code)	Quyền Hạn Nghiệp Vụ	CUSTOMER	SALES_STAFF	WAREHOUSE_MANAGER	ADMIN
book:read	Xem thông tin sách, tác giả, giá, tồn kho	X	X	X	X
order:create	Tạo đơn hàng mới (mua hoặc thuê)	X	X	X	X
order:read:own	Xem danh sách và chi tiết đơn hàng của chính mình	X	X	X	X
rental:read:own	Xem các sách đang thuê và lịch sử thuê của chính mình	X	X	X	X
rental:extend:own	Yêu cầu gia hạn thời gian thuê sách cá nhân	X	X	X	X
subscription:purchase	Đăng ký mua hoặc gia hạn gói hội viên đọc sách	X	X	X	X
order:read:all	Xem danh sách tất cả đơn hàng của mọi khách hàng	-	X	-	X
order:update-status	Cập nhật tiến độ đơn hàng	-	X	-	X

Mã Quyền Hạn (code)	Quyền Hạn Nghịệp Vụ	CUSTOMER	SALES_STAFF	WAREHOUSE_MANAGER	ADMIN
	(CONFIRMED, SHIPPING, COMPLETED)				
rental:read:all	Xem toàn bộ hợp đồng thuê sách và danh sách quá hạn	-	X	-	X
rental:checkin	Xác nhận nhận lại sách thuê, kiểm tra hao mòn và thu hồi cọc	-	X	-	X
order:create:counter	Tạo đơn hàng trực tiếp tại quầy thanh toán cho khách	-	X	-	X
payment:refund	Thực hiện hoàn tiền đơn hủy hoặc đối soát giao dịch ngân hàng	-	X	-	X
copy:manage	Thêm, sửa thông tin bản sao sách vật lý (BookCopy)	-	-	X	X
stock:receive	Tiếp nhận nhập sách mới về kho	-	-	X	X
stock:adjust	Điều chỉnh số lượng tồn kho (hao hụt, hồng hóc)	-	-	X	X
inventory:audit	Kiểm kê thực tế và đối chiếu số lượng trong kho	-	-	X	X

Mã Quyền Hạn (code)	Quyền Hạn Nghiệp Vụ	CUSTOMER	SALES_STAFF	WAREHOUSE_MANAGER	ADMIN
book:manage	Tạo, cập nhật thông tin sách, ảnh bìa, nhãn tủ sách, blog	-	-	-	X
voucher:manage	Tạo, sửa, đóng, xóa mã giảm giá / khuyến mãi	-	-	-	X
subscription:manage	Tạo và quản lý các gói cước hội viên đọc sách	-	-	-	X
user:manage	Xem danh sách người dùng, khóa/mở khóa tài khoản	-	-	-	X
role:assign	Gán vai trò (Roles) và cấp quyền trực tiếp cho tài khoản	-	-	-	X
report:view	Xem báo cáo tài chính, doanh thu bán, doanh thu thuê, tồn kho	-	-	-	X
config:manage	Quản lý cấu hình toàn hệ thống, tham số công thanh toán	-	-	-	X

3. PHÂN TÍCH CHI TIẾT 11 PHÂN HỆ TÍNH NĂNG NGHIỆP VỤ

3.1. Phân Hệ Xác Thực & Tài Khoản (Auth & Identity)

- Đăng ký & Xác thực Email:
- Khách hàng đăng ký tài khoản với username , email , password .

- Mật khẩu được mã hóa an toàn bằng thuật toán **BCrypt** với cost factor tiêu chuẩn.
- Hệ thống tự động tạo mã kích hoạt và gửi email xác thực tài khoản thông qua SMTP Gmail.
- **Đăng nhập & Quản lý Phiên (Token Lifecycle):**
- Endpoint: `POST /api/v1/auth/token` .
- Kiểm tra xác thực thông tin đăng nhập, đối chiếu trạng thái tài khoản (`isActive`).
- Trả về cặp `accessToken` (kèm thời gian hết hạn) và `refreshToken` .
- Endpoint `POST /api/v1/auth/refresh` kiểm tra tính hợp lệ của Refresh Token để cấp mới Access Token mà không làm gián đoạn trải nghiệm người dùng.
- **Đăng xuất & An toàn Tài khoản:**
- Endpoint: `POST /api/v1/auth/logout` .
- Đưa Access Token vào Redis Token Denylist.
- Tăng `user_session_versions` để hủy mọi phiên cũ nếu người dùng yêu cầu đăng xuất khỏi mọi thiết bị.
- **Quên mật khẩu & Đặt lại mật khẩu (HMAC Challenge):**
- Endpoint `POST /api/v1/users/forgot-password` : Tạo chuỗi token bảo mật dựa trên HMAC SHA-256 kết hợp giữa ID người dùng, email, thời gian hết hạn và secret key `RESET_HMAC_SECRET` .
- Không cần lưu trữ token tạm thời vào database (Stateless verification), giảm thiểu gánh nặng I/O và rủi ro rò rỉ dữ liệu.
- Endpoint `POST /api/v1/users/reset-password` : Giải mã, kiểm tra tính toàn vẹn chữ ký HMAC và đổi mật khẩu mới.
- **Sổ Địa Chỉ Giao Hàng (`user_addresses`):**
- Hỗ trợ lưu trữ nhiều địa chỉ nhận hàng cho mỗi khách hàng: Tên người nhận, số điện thoại, địa chỉ chi tiết, tỉnh/thành, quận/huyện, phường/xã.
- Cơ chế tự động quản lý cờ `isDefault` : Khi một địa chỉ được đánh dấu mặc định, hệ thống tự động gỡ bỏ cờ mặc định của các địa chỉ khác của người dùng đó.

3.2. Phân Hệ Danh Mục Sách & Quản Lý Bản Sao Kho (Books & Inventory)

- **Quản lý Đầu Sách (`books`) & Danh mục (`categories`):**
- Sách bao gồm các trường: `title` , `author` , `publisher` , `publicationYear` , `isbn` (duy nhất), `price` (giá mua bìa), `rentalPricePerDay` , `depositPercent` , `summary` , `coverImageUrl` , `isActive` .
- Quan hệ nhiều - nhiều giữa Sách và Thể loại được kết nối qua collection `book_categories` .
- Gắn nhãn phân loại hiển thị theo Tủ sách (`BookShelf`): `NEW_ARRIVALS` (Sách mới về), `BESTSELLERS` (Bán chạy nhất), `FEATURED` (Biên tập viên tuyển chọn), `SALE` (Giảm giá sốc).
- **Thuật toán Gợi ý Sách Bán Chạy (`GetBestsellerSuggestionsService`):**
- Dựa trên dữ liệu thực tế: Tìm kiếm tất cả đơn hàng có trạng thái hợp lệ (`CONFIRMED` , `PROCESSING` , `SHIPPING` , `COMPLETED`) trong vòng `$N$` ngày gần nhất (`since`).
- Tổng hợp (`aggregate`) số lượng mua theo `bookId` từ collection `order_items` , sắp xếp giảm dần và lấy ra top đầu sách bán chạy nhất.
- **Quản lý Bản Sao Sách Vật Lý (`book_copies`):**
- Mỗi cuốn sách vật lý nằm trên kệ được định danh bằng một bản sao độc lập (`BookCopy`).
- Quản lý trạng thái: `AVAILABLE` (Sẵn sàng trên kệ), `RENTED` (Đang được khách thuê), `DAMAGED` (Bị hư hỏng, đang bảo trì), `LOST` (Thất lạc).
- Tình trạng vật lý: `NEW` (Mới 100%), `GOOD` (Tốt 90-95%), `FAIR` (Khá 70-80%), `POOR` (Cũ/xuống cấp).
- **Cơ chế Khóa Bản Sao Chống Tranh Chấp (Pessimistic Lock trên MongoDB):**
- Khi nhiều khách hàng cùng lúc thanh toán thuê một đầu sách mà số lượng bản sao có hạn, hệ thống sử dụng phương thức `findFirstAvailableByBookIdForUpdate()` .
- Thực hiện cập nhật trường `_mongoLock = UUID.randomUUID()` bên trong giao dịch `ClientSession` của MongoDB.
- Thao tác ghi này kích hoạt khóa cấp độ Document trong WiredTiger Engine, khiến các giao dịch khác cố gắng chiếm giữ bản sao này phải chờ hoặc phát hiện xung đột ghi (`WriteConflict`), loại trừ hoàn toàn nguy cơ một cuốn sách bị cho hai người thuê cùng lúc.

3.3. Phân Hệ Giỏ Hàng Đa Hình (Dual-mode Shopping Cart)

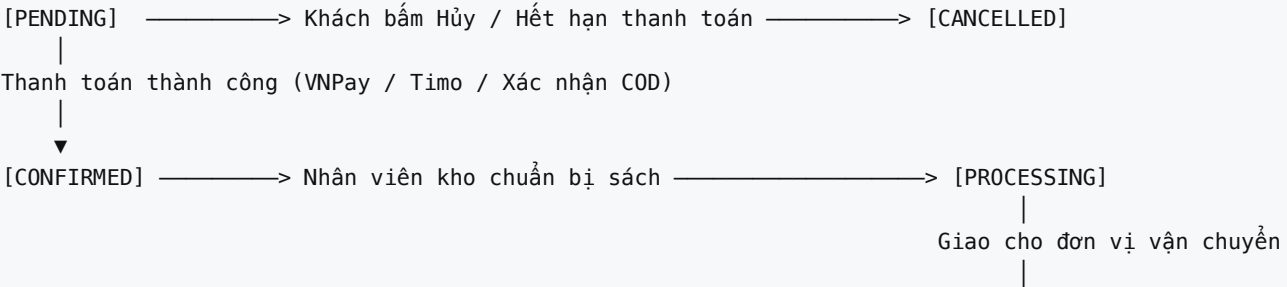
- **Cấu trúc Giỏ hàng (carts & cart_items):**
- Mỗi người dùng sở hữu duy nhất một giỏ hàng (`unique("carts", "userId")`).
- Giỏ hàng hỗ trợ cùng lúc hai chế độ sản phẩm:
 - 1. **Mua sách (itemType = "PURCHASE"):** Mua sở hữu vĩnh viễn, đơn giá theo giá bán bìa.
 - 2. **Thuê sách (itemType = "RENTAL"):** Thuê có thời hạn với kỳ hạn linh hoạt (`rentalTermValue` và `rentalTermUnit`: DAY, WEEK, MONTH).
- **Xử lý Hợp nhất Sản phẩm (Deduplication & Auto-merge):**
- Chỉ mục duy nhất phức hợp `uk_cart_items_cartId_bookId_itemType_rentalTermValue_rentalTermUnit` ngăn chặn bản ghi rác.
- Khi khách hàng thêm vào giỏ một sản phẩm có cùng `bookId`, cùng `itemType` và cùng thời hạn thuê, hệ thống tự động cộng dồn số lượng (`quantity += newQuantity`) thay vì tạo dòng mới.
- **Tính toán Giá Trị Đơn Hàng Tạm Tính:**
- Phí mua = `price * quantity`.
- Phí thuê = `rentalPricePerDay * số ngày quy đổi * quantity`.
- Tiền cọc sách thuê (`depositAmount`) = `(price * depositPercent / 100) * quantity`.
- Tiền cọc sẽ được hoàn trả lại cho khách sau khi trả sách đúng hạn và nguyên vẹn.

3.4. Phân Hệ Khuyến Mãi & Voucher Engine (Quote, Reserve, Commit)

- **Định dạng Voucher (vouchers):**
- Mã voucher độc nhất (`code`), ví dụ: CHAOHEXUAN, GIAM20K, FREESHIP.
- Loại giảm giá: PERCENTAGE (% giá trị đơn hàng, đi kèm `maxDiscountAmount`) hoặc FIXED_AMOUNT (giảm số tiền cụ thể).
- Điều kiện ràng buộc: Giá trị đơn hàng tối thiểu (`minOrderValue`), ngày bắt đầu (`startAt`), ngày kết thúc (`endAt`), tổng số lượt sử dụng tối đa (`maxUsages`), giới hạn sử dụng mỗi khách hàng (`maxUsagesPerUser`).
- **Quy trình 3 bước xử lý Voucher (Two-phase Commit Pattern):** 1. **Bước 1 - Trích dẫn (Quote):** Khi khách hàng áp mã trên giao diện, hệ thống kiểm tra điều kiện và tính toán số tiền giảm thực tế mà không trừ lượt dùng. 2. **Bước 2 - Giữ chỗ (Reserve):** Khi bấm "Đặt hàng", hệ thống tạo bản ghi trạng thái RESERVED trong `voucher_usages`. Bước này giữ chỗ để tránh tình trạng nhiều người cùng thanh toán vượt quá hạn mức voucher. 3. **Bước 3 - Chốt lượt dùng (Commit):** Sau khi nhận thông báo thanh toán thành công từ VNPay hoặc Ngân hàng, hệ thống chuyển trạng thái `voucher_usages` sang COMMITTED và tăng biến đếm sử dụng trong `vouchers`. Nếu đơn hàng bị hủy trước khi thanh toán, hệ thống giải phóng bản ghi RESERVED.

3.5. Phân Hệ Đặt Hàng & Quản Lý Vòng Đời Đơn Hàng (Order Lifecycle)

- **Đa hình Đơn hàng (OrderType):**
- PURCHASE : Đơn thuần mua sách.
- RENTAL : Đơn thuần thuê sách.
- MIXED : Đơn kết hợp cả sách mua và sách thuê trong cùng một lần thanh toán.
- **Máy Trạng Thái Đơn Hàng (Order State Machine):**



[COMPLETED] <————— Giao thành công & Khách nhận hàng <————— [SHIPPING]

- **Lịch sử Biến động Trạng thái (`order_status_history`):**
- Mỗi lần chuyển trạng thái đơn hàng đều sinh một bản ghi kiểm toán bất biến: `orderId` , `status` , `source` (ví dụ: `CUSTOMER_ACTION` , `PAYMENT_WEBHOOK` , `STAFF_UPDATE`) , `changedAt` .
- Đảm bảo tính minh bạch, hỗ trợ truy vết khi xảy ra khiếu nại giữa khách hàng và bộ phận vận hành.

3.6. Phân Hệ Thanh Toán & Đối Soát Ngân Hàng Tự Động (Payment & Bank Reconciliation)

- **Tích hợp Cổng thanh toán VNPAY:**
- Hỗ trợ thanh toán qua Thẻ ATM nội địa, Thẻ quốc tế (Visa/Mastercard), Ứng dụng Mobile Banking quét VNPAY-QR.
- Sinh URL chuyển hướng với tham số bảo mật và chữ ký số **HMAC-SHA512** (`vnp_SecureHash`).
- Xử lý Callback đồng bộ cho trình duyệt khách hàng và Webhook IPN (`Instant Payment Notification`) bất đồng bộ từ máy chủ VNPAY: Xác thực chữ ký, kiểm tra số tiền, cập nhật trạng thái đơn hàng thành `PAID` và `CONFIRMED` .
- **Hệ thống Thanh toán Chuyển khoản Tự động (VietQR + BVBank / Timo IMAP Poller):**
- **Sinh mã QR chuẩn Napas247:** Sử dụng mã BIN 970454 (BVBank - Timo), số tài khoản thụ hưởng, số tiền chính xác và cú pháp chuyển tiền chứa mã thanh toán độc nhất dạng `PAY-<orderId>--<hash>` .
- **Công cụ quét hòm thư ngân hàng (IMAP Poller):**
 - Service nền định kỳ quét hộp thư đến (Gmail IMAP SSL port 993).
 - Phân tích cú pháp email báo biến động số dư từ ngân hàng (`support@timo.vn`).
 - Xác thực nguồn gốc email thông qua `Authentication-Results` (SPF pass, DKIM pass) tránh giả mạo email.
- **Cơ chế Chống Trùng Lặp (`processed_bank_messages`):**
 - Lưu lại `messageId` của email và mã giao dịch ngân hàng (`bankTxnRef`).
 - Nếu một giao dịch đã xử lý, poller lập tức bỏ qua, ngăn chặn cập nhật đơn hàng hai lần.
- **Tự động Khớp Lệnh & Xử lý Ngoại Lệ (`unmatched_transfers`):**
 - Khớp mã chuyển khoản và số tiền `$\rightarrow$` Tự động đổi trạng thái đơn hàng sang `PAID` , kích hoạt gói hội viên và khởi động tiến trình giao sách thuê.
 - Nếu khách chuyển thiếu tiền, chuyển thừa tiền, hoặc viết sai nội dung chuyển khoản `$\rightarrow$` Hệ thống tự động đẩy vào collection `unmatched_transfers` .
 - Cung cấp giao diện Quản trị Đối soát (`/admin/doi-soat`): Cho phép kế toán viên xem danh sách giao dịch treo, tra cứu thông tin và đối soát thủ công (`ResolveUnmatchedTransferService`) để kích hoạt đơn hàng đúng cho khách.

3.7. Phân Hệ Thuê Sách & Gói Hội Viên Đọc Sách (Rentals & Subscriptions)

- **Thuê Sách Theo Từng Đầu Sách (On-demand Book Rental):**
- Khách hàng thuê sách kèm đặt cọc. Thời hạn thuê tính theo ngày/tuần/tháng.
- Sau khi đơn hàng thanh toán thành công, tiến trình `RentalFulfillmentService` tự động quét các bản sao `AVAILABLE` của đầu sách đó trong kho, chuyển trạng thái bản sao sang `RENTED` và tạo hợp đồng thuê (`rentals`) với `startDate` và `plannedReturnDate` .
- **Gói Hội Viên Đọc Sách VIP (`subscriptions` & `customer_subscriptions`):**
- Khách hàng đăng ký gói thuê tháng (ví dụ: Gói Cơ bản 3 tháng, Gói Đọc vô hạn 12 tháng).
- Quyền lợi hội viên: Thuê sách không cần đặt cọc, giảm giá phí vận chuyển, quyền mượn cùng lúc nhiều đầu sách.
- Quản lý trạng thái gói: `ACTIVE` , `EXPIRED` , `CANCELLED` . Hỗ trợ gia hạn gói trước khi hết hạn.
- **Quy Trình Trả Sách & Hoàn Cọc (`ReturnRentalService`):**
- Khách hàng gửi trả sách về nhà sách (trực tiếp tại quầy hoặc qua bưu điện).

- Nhân viên tiếp nhận kiểm tra tình trạng vật lý của sách:
 - Nếu sách nguyên vẹn và đúng hạn: Hoàn trả 100% tiền đặt cọc vào tài khoản/ví của khách.
 - Nếu trả muộn: Tính phí phạt quá hạn theo số ngày trễ nhân với đơn giá ngày, khấu trừ trực tiếp vào tiền cọc.
 - Nếu sách bị hư hại hoặc mất: Chuyển trạng thái bản sao sang `DAMAGED` hoặc `LOST`, khấu trừ một phần hoặc toàn bộ tiền cọc tương ứng với giá trị bìa sách.
- Tính năng `Force Return` (`force-return`): Áp dụng khi khách hàng quá hạn quá lâu không liên lạc được, cho phép thu ngân đóng hợp đồng và tất toán tiền cọc tích thu.

3.8. Phân Hệ Hỗ Trợ Khách Hàng Trực Tuyến (Live Support Chat)

- **Hội thoại Hỗ trợ (`support_conversations`):**
- Mỗi khách hàng có một kênh hội thoại riêng với bộ phận chăm sóc khách hàng.
- Quản lý trường đếm tin chưa đọc độc lập: `staffUnreadCount` (tin khách gửi nhân viên chưa đọc) và `customerUnreadCount` (tin nhân viên phản hồi khách chưa đọc).
- **Trao đổi Tin nhắn & Đính kèm Tập Đa Phương Tiện:**
- Tin nhắn (`support_messages`) phân biệt người gửi: `CUSTOMER` hoặc `STAFF`.
- Hỗ trợ gửi ảnh chụp thực tế (sách bị rách, ảnh chụp biên lai chuyển tiền) qua `support_message_attachments`.
- Tập tài lên được lưu trữ cục bộ có bảo vệ danh mục (`LocalSupportAttachmentStorage`) và cấp phát URL an toàn `/media/**`.

3.9. Phân Hệ Đánh Giá Sách Đã Xác Minh (Verified Reviews)

- **Cơ chế Kiểm duyệt Tính Hợp Lệ (`ReviewEligibilityRepository`):**
- Để ngăn chặn đánh giá ảo hoặc spam, hệ thống áp dụng cơ chế xác minh chặt chẽ: Chỉ người dùng đã từng **mua thành công** (đơn hàng trạng thái `PAID / COMPLETED`) hoặc **đã thuê và hoàn tất trả sách** mới được gửi đánh giá cho đầu sách đó.
- Phân loại nguồn gốc đánh giá (`ReviewSource`): Đánh dấu nhãn minh bạch `PURCHASE` (Người mua sách) hoặc `RENTAL` (Người thuê sách).
- **Nội dung Đánh giá (`book_reviews`):**
- Điểm số xếp hạng: Từ 1 đến 5 sao.
- Tiêu đề tóm tắt và bình luận chi tiết cảm nhận của độc giả.
- Chỉ mục duy nhất phức hợp `uk_book_reviews_userId_orderItemId` bảo đảm mỗi lần mua/thuê chỉ được đánh giá 1 lần duy nhất, hỗ trợ tính năng cập nhật đánh giá đã đăng.

3.10. Phân Hệ Thông Báo Đa Kênh & Thời Gian Thực (SSE & Web Push)

- **Trung Tâm Thông Báo In-App (`user_notifications`):**
- Lưu trữ các loại thông báo (`NotificationType`): `ORDER` (Cập nhật trạng thái đơn), `PAYMENT` (Xác nhận tiền về), `RENTAL` (Nhắc lịch trả sách, gia hạn), `SUPPORT` (Phản hồi chat hỗ trợ), `SYSTEM` (Tin tức, voucher mới).
- Quản lý trạng thái đọc: `readAt`, đếm nhanh số lượng chưa đọc (`unreadCount`), đánh dấu đã đọc từng tin hoặc đọc tất cả.
- **Đẩy Dữ Liệu Thời Gian Thực Qua Server-Sent Events (SSE):**
- Endpoint: `GET /api/v1/notifications/stream`.
- Khi có sự kiện phát sinh (ví dụ: tiền chuyển khoản vừa khớp lệnh), máy chủ lập tức đẩy gói tin `NotificationEvent` xuống client qua kết nối HTTP bền vững mà client không cần tốn tài nguyên polling liên tục.
- **Thông Báo Đẩy Trình Duyệt (Web Push qua Service Worker):**
- Hoạt động ngay cả khi người dùng đã đóng trang web hoặc tắt trình duyệt.
- Sử dụng chuẩn mã hóa **VAPID**: Client đăng ký `endpoint`, `p256dh`, `auth` lưu vào `push_subscriptions`.

- Máy chủ ký thông điệp bằng khóa riêng tư (`private-key`) và đẩy thông báo qua dịch vụ Push Service của hệ điều hành/trình duyệt.

3.11. Phân Hệ Quản Trị Nội Dung & Blog Sách (Editorial CMS)

- Quản lý Bài Viết Sách (`blog_posts`):**
- Nội dung phong phú: Tiêu đề, tóm tắt bài viết, nội dung chi tiết hỗ trợ định dạng Markdown, ảnh đại diện bìa (`coverImageUrl`), danh mục chủ đề, tác giả.
- Cơ chế tạo đường dẫn thân thiện với SEO: `slug` duy nhất (ví dụ: `top-10-cuon-sach-khoa-hoc-dang-doc-nhat-2026`).
- Quản lý trạng thái xuất bản: `DRAFT` (Bản nháp nội bộ) và `PUBLISHED` (Đã phát hành ra công chúng kèm mốc thời gian `publishedAt`).
- Phân quyền: Độc giả chỉ đọc bài viết đã phát hành; Quản trị viên (`book:manage`) toàn quyền tạo, chỉnh sửa nội dung, xuất bản hoặc gỡ bài viết.

4. BẢNG TỔNG HỢP REST API ENDPOINTS TOÀN HỆ THỐNG

Method	Endpoint	Yêu Cầu Bảo Mật / Phân Quyền	Chức Năng Nghiệp Vụ
POST	<code>/api/v1/auth/token</code>	Public	Đăng nhập hệ thống, cấp Access & Refresh Token
POST	<code>/api/v1/auth/refresh</code>	Public	Cấp mới Access Token bằng Refresh Token
POST	<code>/api/v1/auth/logout</code>	Authenticated	Đăng xuất, vô hiệu hóa Access Token vào Redis denylist
POST	<code>/api/v1/users/register</code>	Public	Đăng ký tài khoản người dùng mới
POST	<code>/api/v1/users/verify-email</code>	Public	Xác thực email đăng ký tài khoản
POST	<code>/api/v1/users/forgot-password</code>	Public	Gửi yêu cầu đặt lại mật khẩu qua email
POST	<code>/api/v1/users/reset-password</code>	Public	Xác thực HMAC token và cập nhật mật khẩu mới
GET	<code>/api/v1/users/me</code>	Authenticated	Lấy thông tin hồ sơ người dùng hiện tại
PUT	<code>/api/v1/users/me</code>	Authenticated	Cập nhật thông tin cá nhân
PUT	<code>/api/v1/users/me/password</code>	Authenticated	Đổi mật khẩu tài khoản

Method	Endpoint	Yêu Cầu Bảo Mật / Phân Quyền	Chức Năng Nghiệp Vụ
GET	/api/v1/addresses	Authenticated	Lấy danh sách địa chỉ giao hàng của người dùng
POST	/api/v1/addresses	Authenticated	Thêm mới địa chỉ nhận hàng
PUT	/api/v1/addresses/{id}	Authenticated	Chỉnh sửa thông tin địa chỉ nhận hàng
DELETE	/api/v1/addresses/{id}	Authenticated	Xóa địa chỉ nhận hàng
GET	/api/v1/books/**	Public	Xem danh sách sách, chi tiết sách, lọc theo danh mục/tủ sách
GET	/api/v1/categories	Public	Lấy danh mục thể loại sách
GET	/api/v1/books/bestseller-suggestions	book:manage	Gợi ý sách bán chạy dựa trên tổng hợp dữ liệu đơn
PUT	/api/v1/books/{id}/flags	book:manage	Cập nhật cờ hiển thị sách (Nổi bật, Mới, Bán chạy)
POST	/api/v1/books/{id}/cover	book:manage	Tải lên ảnh bìa sách
GET	/api/v1/books/{bookId}/copies	book:manage	Xem danh sách bản sao vật lý của đầu sách
POST	/api/v1/books/{bookId}/copies	book:manage	Thêm mới bản sao sách vật lý vào kho
PATCH	/api/v1/book-copies/{copyId}	book:manage	Cập nhật trạng thái/tình trạng bản sao sách
GET	/api/v1/cart	Authenticated	Xem giỏ hàng cá nhân
POST	/api/v1/cart/items	Authenticated	Thêm sách vào giỏ (chế độ mua hoặc thuê)
PUT	/api/v1/cart/items/{itemId}	Authenticated	Cập nhật số lượng hoặc thời hạn thuê của sản phẩm trong giỏ
DELETE	/api/v1/cart/items/{itemId}	Authenticated	Xóa sản phẩm khỏi giỏ hàng
POST	/api/v1/vouchers/quote	Authenticated	Kiểm tra và tính toán mức giảm của voucher

Method	Endpoint	Yêu Cầu Bảo Mật / Phân Quyền	Chức Năng Nghiệp Vụ
			cho đơn hàng
GET	/api/v1/vouchers	voucher:manage	Quản lý danh sách tất cả voucher hệ thống
POST	/api/v1/vouchers	voucher:manage	Tạo mới voucher khuyến mãi
PUT	/api/v1/vouchers/{id}	voucher:manage	Cập nhật thông tin voucher
DELETE	/api/v1/vouchers/{id}	voucher:manage	Hủy hoặc xóa voucher
POST	/api/v1/orders	Authenticated	Đặt hàng (tạo đơn mua, đơn thuê hoặc đơn hỗn hợp)
GET	/api/v1/orders/me	Authenticated	Lấy danh sách lịch sử đơn hàng của tôi
GET	/api/v1/orders/me/summary	Authenticated	Thống kê số lượng đơn theo từng trạng thái
GET	/api/v1/orders/{id}	Authenticated	Xem chi tiết một đơn hàng của tôi
POST	/api/v1/orders/{id}/cancel	Authenticated	Khách hàng tự hủy đơn hàng khi còn ở trạng thái PENDING
GET	/api/v1/orders	order:read:all	Nhân viên/Admin xem toàn bộ đơn hàng hệ thống
PUT	/api/v1/orders/{id}/status	order:update-status	Cập nhật trạng thái đơn (CONFIRMED, SHIPPING, COMPLETED)
POST	/api/v1/payment/vnpay/create	Authenticated	Khởi tạo giao dịch thanh toán qua cổng VNPay
GET	/api/v1/payment/vnpay/callback	Public	Nhận kết quả điều hướng thanh toán từ VNPay
POST	/api/v1/payment/vnpay/ipn	Public	Webhook máy chủ VNPay gửi thông báo giao dịch thành công

Method	Endpoint	Yêu Cầu Bảo Mật / Phân Quyền	Chức Năng Nghiệp Vụ
POST	/api/v1/payment/bank-transfer/create	Authenticated	Tạo lệnh thanh toán chuyển khoản ngân hàng VietQR
GET	/api/v1/payment/bank-transfer/{orderId}/qr	Authenticated	Lấy thông tin mã QR chuyển khoản động Napas247
GET	/api/v1/bank-transfers/unmatched	payment:refund	Danh sách các khoản tiền chuyển khoản chưa khớp tự động
POST	/api/v1/bank-transfers/unmatched/{id}/resolve	payment:refund	Nhân viên đối soát và khớp thủ công khoản tiền vào đơn hàng
GET	/api/v1/rentals/me	Authenticated	Xem danh sách sách đang thuê của tôi
POST	/api/v1/rentals/{id}/return	Authenticated	Khách hàng gửi yêu cầu trả sách thuê
GET	/api/v1/rentals	rental:read:all	Quản lý toàn bộ danh sách hợp đồng thuê sách
GET	/api/v1/rentals/overdue	rental:read:all	Danh sách các hợp đồng thuê sách quá hạn trả
POST	/api/v1/rentals/{id}/force-return	rental:checkin	Nhân viên đóng cưỡng chế hợp đồng thuê quá hạn
GET	/api/v1/subscriptions	subscription:manage	Quản lý các gói hội viên đọc sách
POST	/api/v1/subscriptions	subscription:manage	Thêm mới gói cước đọc sách hội viên
POST	/api/v1/subscriptions/purchase	Authenticated	Đăng ký mua gói cước hội viên
GET	/api/v1/subscriptions/me/active	Authenticated	Xem gói cước hội viên hiện tại đang kích hoạt
POST	/api/v1/books/{bookId}/reviews	Authenticated	Đăng bài đánh giá cho sách đã mua/thuê
GET	/api/v1/reviews/books/{bookId}/me	Authenticated	Kiểm tra điều kiện đánh giá của tôi cho đầu

Method	Endpoint	Yêu Cầu Bảo Mật / Phân Quyền	Chức Năng Nghiệp Vụ
			sách
GET	/api/v1/support/conversation	Authenticated	Lấy cuộc hội thoại hỗ trợ của khách hàng
POST	/api/v1/support/conversation/messages	Authenticated	Gửi tin nhắn và đính kèm hình ảnh lên nhân viên hỗ trợ
GET	/api/v1/support/conversations	order:read:all	Nhân viên xem danh sách các cuộc trò chuyện của khách
GET	/api/v1/notifications	Authenticated	Xem danh sách thông báo in-app
PATCH	/api/v1/notifications/{id}/read	Authenticated	Đánh dấu đã đọc một thông báo
GET	/api/v1/notifications/stream	Authenticated	Kết nối SSE lắng nghe sự kiện thông báo thời gian thực
POST	/api/v1/notifications/push/subscriptions	Authenticated	Đăng ký thiết bị nhận thông báo đẩy Web Push
GET	/api/v1/blog-posts	Public	Đọc danh sách bài viết giới thiệu sách
GET	/api/v1/blog-posts/{slug}	Public	Đọc chi tiết bài viết theo đường dẫn SEO
POST	/api/v1/blog-posts	book:manage	Tạo mới bài viết biên tập
POST	/api/v1/blog-posts/{id}/publish	book:manage	Xuất bản bài viết ra trang chủ